

NVIDIA 安全代理工作空间（Secure Agent Workspace）参考设计 — 完整中文翻译

第1章：始终在线、自主运行的代理（Agent），现在可为AI工厂安全部署

企业正从聊天式助手转向"始终在线个人代理"，这些代理能够阅读代码、检查文档、运行测试、查询系统、起草更新，并代表单个员工持续运行数小时。这一转变催生了一项新的平台需求：一个用于自主代理执行的"安全的、受管控的代理工作空间（secure, managed agent workspace）"。

安全代理工作空间（Secure Agent Workspace）为企业提供了一个受管控的自主代理运行场所。用户端点（endpoint）作为接入层连接，但实际执行发生在受管控的工作空间内，其中身份（identity）、网络访问（network access）、凭据（credentials）、运行时策略（runtime policy）、审计（audit）和人工审查（human review）共同约束代理的行为能力。

用户端点是一个展示层（presentation layer），而非执行层（execution layer）。代理运行时（agent runtime）在被管控的远程环境（单用户虚拟机，可选GPU加速）内执行，该环境通过经批准的完整生命周期（lifecycle）进行配置，经由可信代理（trusted broker）访问，受运行时执行层（runtime enforcement layer）约束，并通过受管控的连接器（governed connectors）与企业系统连接，敏感写操作需经过人工审查。

防护目标： 未经授权或意外的写操作、数据外泄（data exfiltration）、提示注入（prompt injection）、代理作为攻击者（agent-as-attacker，出站滥用）、虚拟机内root权限失陷（in-VM root compromise）。

成果： 员工获得一个持久化的工作空间，代理可在其中无限期运行。安全团队获得身份网关（identity gates）、出站策略（egress policy）、凭据隔离（credential isolation）、审计日志（audit logs）以及人工审查控制。平台团队获得可支撑AI工厂规模（AI Factory scale）的参考模式。

成熟度模型（Maturity Model）：

- **第一阶段（Phase I）：** 代理在托管虚拟机中运行（工作空间边界控制，workspace-perimeter controls）。
- **第二阶段（Phase II）：** 签名策略强制执行的运行时沙箱（runtime sandbox）（NVIDIA OpenShell 或等效方案），具备运行时内默认拒绝出站（deny-by-default in-runtime egress）、凭据代理（credential proxying）、路由推理（routed inference）、文件系统和进程范围限定（filesystem

and process scoping) 。

第2章：什么是安全代理工作空间？

一个受管控的场所，自主工作在此运行——对用户主机设备、外部互联网和企业网络的访问均在基础设施层面进行监控，处于大语言模型（LLM）信任边界之外。

组件构成：

- 工作空间环境（workspace environment）——受管控的Linux/Windows虚拟机
- 门户/API（Portal/API），用于生命周期管理
- 终端/IDE/GUI接入（Terminal/IDE/GUI attachment）
- 可选的GPU加速（GPU acceleration）
- 运行时受限的代理执行（runtime-bounded agent execution）——OpenShell
- 代理框架组件（agent-framework components）——NemoClaw、AI-Q Blueprints、NeMo Agent Toolkit
- 可信访问代理（trusted access broker）——企业SSO（单点登录）、短时会话（short-lived sessions）
- 分层身份表面（layered identity surface）——用户/主办者（user/sponsor）、工作空间（workspace）、代理（agent）、每次调用的凭据（per-call credential）
- 每次委托的记录（per-engagement delegation record）
- 代理治理层（agent governance layer）——签名策略（signed-policy）、遥测（telemetry）、审计（audit）、人工审查（human-review）
- 对企业系统的受管控访问（governed access to enterprise systems）

第3章：安全代理工作空间不是什么

安全代理工作空间不是：

- 用于提供生产应用程序的平台
- 绕过网络控制的手段
- 安全审查的替代品
- 多用户共享工作空间
- 身份提供者（identity provider）

- 代理在工作空间之外执行的架构

每个工作空间是单用户、单租户（single-tenant）的虚拟机。容器级隔离（container-level isolation）不足以满足安全要求——代理执行任意代码，沙箱逃逸（sandbox escape）会波及相邻工作负载。虚拟机隔离（VM isolation）是前提条件。

第4章：安全代理工作空间的适用场景

四种使用场景（Four use cases）：

1. 本地端点（Local endpoint） — 日常开发工作
2. 公共配置文件（Public profile） — 开源/公开数据工作
3. 企业配置文件（Corporate profile） — 使用内部依赖的自主开发
4. 服务托管平台（Service-hosting platform）

能力风险模型（Capability Risk Model） — 三要素法则（Rule of Three）：

风险随着以下三个要素的叠加而加剧：

- (a) 内部数据访问（internal data access）
- (b) 自主性（autonomy）
- (c) 外部数据访问（external data access）

企业配置文件（Corporate profile）约束了要素(c)；公共配置文件（Public profile）消除了要素(a)。

三个时间尺度（Three timescales）：

- 长期运行（Long-running）——虚拟机本身
 - 每次会话（Per-session）——OpenShell沙箱
 - 每次命令（Per-command）——临时Pod（ephemeral pod）
-

第5章：参考架构

七个逻辑平面（Seven Logical Planes）。

架构不变量（Architectural Invariants）：

- 原始凭据（raw credentials）不进入代理

- 无自我授权 (no self-granted authority)
- 不连接未列入清单的目的地 (no connection to unlisted destination)
- 不篡改系统二进制文件 (no tampering with system binaries)
- 代理不创建持久化 (no agent-created persistence)
- 代理不控制生命周期 (no agent-controlled lifecycle)
- 不压制审计 (no suppressed audit)

网络架构 (Network Architecture)： 代理网络形态 (brokered network shape)，可信访问代理是唯一的信任边界 (trust boundary)。

可信访问代理 (Trusted Access Broker)： 仅限SSO、短时会话、OCSF审计 (OCSF audit)、撤销传播 (revocation propagation)，代理的是会话 (sessions) 而非令牌 (tokens)。

凭据代理 (Credential Proxy)： 位于出站路径中，持有密钥 (secrets)，代理获取的是能力 (capabilities) 而非凭据。

推理 (Inference)： 硬依赖 (hard dependency)，两种模式 (本地/路由)，GPU加速独立于推理。

第6章：代理蓝图模式

蓝图 (Blueprints) 是可重复的工作流模板。

安全态势规则 (Posture Rules)：

- 从最小范围开始 (Start narrow) —— 最小权限 (least-privilege)
- 写操作需要人工审查 (writes require human review)
- 静态策略 (static policy)
- 纵深防御 (defense in depth)
- 生命周期所有权 (lifecycle ownership)
- 默认始终在线 (always-on by default)

蓝图目录 (Blueprint catalog)：

- 编码 (Coding)
- 文档编写 (Documentation)
- 问题分类 (Issue triage)

- 开发者入职（Developer onboarding）
- 研究笔记本（Research notebook）
- 运维（Operations）
- 知识工作者（Knowledge worker）

写操作门控（Write gating）： 代理将内容写入私有暂存区（private staging surface），提出人工审批建议（分支 + MR/PR模式）。

第7章：企业工具访问模型

三个层次（Three layers）：

1. 网络可达性（Network reach）——允许清单（allowlist）
2. 按服务的认证（Per-service authentication）
3. 动作类别（Action class）——按蓝图（per blueprint）

授权（Authorization）： 四身份链（four-identity chain），每次委托的记录（per-engagement delegation record）是用户权限的策略定义子集（policy-defined subset）。委托严格衰减（strictly attenuating）。

服务类别访问模型（Service Category Access Model）：

服务类别	自动运行（autorun）vs 人工审查（human-review）动作
源代码管理（Source control）	读自动运行，写需审查
工作跟踪（Work tracking）	读自动运行，写需审查
文档（Documentation）	读自动运行，写需审查
聊天（Chat）	需审查
邮箱（Mailbox）	需审查
包仓库（Package repos）	读自动运行
数据存储（Data stores）	读自动运行，写需审查
模型端点（Model endpoints）	路由推理（routed inference）
外部互联网（External internet）	受限/无

第8章：安全与治理模型

三层防护包络（Three-layer envelope）：

1. 基线托管工作空间控制（Baseline managed-workspace controls）
2. 运行时沙箱控制（Runtime sandbox controls）
3. 签名策略治理（Signed-policy governance）

控制面（Control Surface）— 六个领域：

- 工作空间（Workspace）
- OpenShell / 运行时（Runtime）
- 签名策略（Signed-policy）
- 身份 / 委托（Identity / delegation）
- 凭据中介（Credential mediation）
- 审计 / 撤销（Audit / revocation）

威胁模型（Threat Model）：

代理级别（Agent-level）→ 非特权用户空间（Unprivileged user-space）→ 操作系统root权限（Root-on-OS）→ 虚拟机监控器失陷（Hypervisor compromise），每一级均有残余控制（residual controls）。

机密计算（Confidential compute）：可选的TEE（可信执行环境，Trusted Execution Environment）。

DPU/SmartNIC：可选的BlueField/ConnectX卸载（offload）。

第9章：运行属性

八项属性（8 properties）：

1. 所有者/主办者背书（owner/sponsor-backed）
2. 权限源自注册所有者（authority from registered owner）
3. 一次引导（bootstrap once）
4. 短时会话（short-lived sessions）
5. 允许清单制出站（allowlisted outbound）
6. 固定配置文件（fixed profile）
7. 单租户（single-tenant）

- 8. 临时状态 (ephemeral state)
- 9. 写操作经人工审查 (human-reviewed writes)

第10章：部署层级

五个层级 (Five tiers)：

层级	描述
CPU VM	基于CPU的虚拟机
GPU VM/工作站 (GPU VM/workstation)	基于GPU的虚拟机或工作站
桌面侧加速工作站 (Deskside accelerated workstation)	本地GPU加速工作站
团队共享系统 (Team shared system)	团队级共享资源
平台集群 (Platform fleet)	大规模平台部署

第11章：Red Hat OpenShift虚拟化参考实现

本地部署 (On-premise)：

- 每个用户一个持久虚拟机 (persistent VM)
- GitOps / Argo CD
- NFS存储 (NFS storage)
- 可信访问代理 (trusted access broker)

第一阶段 (Phase I)：可部署的托管虚拟机控制 (Deployable Managed VM Controls)。

第二阶段 (Phase II)：使用OpenShell的运行时强制代理策略 (Runtime-Enforced Agent Policy with OpenShell)。

第12章：Microsoft Azure参考实现

云端部署 (Cloud)：

- 临时单用户Azure Linux虚拟机 (ephemeral single-user Azure Linux VM)
- 专用不可信虚拟网络 (dedicated untrust VNet)

- Azure防火墙高级版 (Azure Firewall Premium)
- NAT网关V2 (NAT Gateway V2)
- 工作负载身份联合 (Workload Identity Federation) ——无密钥 (secretless)
- Microsoft Entra ID
- 可信访问代理 (trusted access broker)

第一阶段 (Phase I) : "虚拟机即为沙箱 (VM is the sandbox) 。”

第二阶段 (Phase II) : 虚拟机内运行时执行 (in-VM runtime enforcement) 。

本文档基于 *NVIDIA Secure Agent Workspace Reference Design* 翻译，用于企业内部架构参考。技术术语首次出现时保留英文原文，后续使用中文翻译。